aws raid

Cloud Infrastructure Incident Analysis & S3 Exfiltration Report

Affected Cloud Environment	AWS Cloud Infrastructure (IAM & S3 Object Storage)
Compromised IAM Identity	`helpdesk.luke`
Suspected Attacker IP Range	`185.192.70.0/24` (Primary C2 source: `185.192.70.78`)
Primary Vectors	Console Login Brute Force, S3 Data Exfiltration, Public Access Block Modification, Backdoor IAM User Provisioning
Impacted Storage Buckets	`research-project-files23411723`, `product-designs-repository31183937`, `marketing-assets-vault27512203`, `legal-docs45020393`, `customer-data-backup57893984`, `backup-and-restore98825501`
Overall Investigation Result	Confirmed multi-stage cloud compromise: initial credential brute forcing against multiple employee accounts, successful takeover of support staff identity, systematic sensitive data theft from S3 buckets, alteration of bucket public access blocks, and creation of administrative backdoor account `marketing.mark`.

1. Executive Summary

Security operations monitoring identified suspicious authentication anomalies across the enterprise AWS CloudTrail logs. Ingested SIEM telemetry analyzed via Splunk revealed an automated credential brute-force campaign targeting several internal IAM user accounts.

The threat actor successfully compromised the user identity `helpdesk.luke` following repeated authentication failures. Once inside the management console, the adversary executed automated discovery and exfiltration scripts, downloading sensitive intellectual property, CAD drawings, legal agreements, and customer database backups from multiple AWS S3 buckets. Additionally, the attacker reconfigured S3 public access security blocks and established long-term persistence by provisioning a backdoor administrative IAM user.

2. Scope and Evidence

This report details forensic findings extracted from AWS CloudTrail event logs ingested into Splunk. Analysis covered IAM console logins, S3 bucket metadata requests, storage object retrieval events, security block configurations, and IAM privilege escalation actions.

3. Attack Timeline

Timestamp (UTC)	Event Name	Actor Identity	Source IP / Details
2023-11-02 07:37:14	`ConsoleLogin` (Failure)	`helpdesk.luke`	Initial failed authentication attempt during password spray.
2023-11-02 07:37:23	`ConsoleLogin` (Success)	`helpdesk.luke`	First successful console login session.
2023-11-02 09:53:27	`ConsoleLogin` (Failure)	`helpdesk.luke`	Start of secondary focused brute force sequence (9 failures).
2023-11-02 09:54:04	`ConsoleLogin` (Success)	`helpdesk.luke`	Successful secondary authentication establishing active session.
2023-11-02 09:55:47	`ListObjects`	`helpdesk.luke`	Enumeration of `research-project-files23411723` bucket.
2023-11-02 09:55:53	`GetObject`	`helpdesk.luke`	Exfiltration of `prototype.obj` from research bucket.
2023-11-02 09:56:07	`GetObject`	`helpdesk.luke`	Exfiltration of `Product2_CAD_Designs.dwg`.
2023-11-02 09:56:39	`GetObject`	`helpdesk.luke`	Exfiltration of `CustomerData_Backup_2023-11-01.zip`.
2023-11-02 09:58:01	`PutBucketPublicAccessBlock`	`helpdesk.luke`	Modified public access block on `backup-and-restore98825501`.
2023-11-02 09:59:33	`CreateUser`	`helpdesk.luke`	Provisioning of backdoor IAM identity `marketing.mark`.
2023-11-02 09:59:38	`AddUserToGroup`	`helpdesk.luke`	Assigning `marketing.mark` to the `Admins` group.

4. Investigation Phases

Phase 1 - Initial Access & Credential Brute-Forcing

Analysis began with querying CloudTrail logs for failed AWS Management Console logins using the Splunk search syntax `eventName="ConsoleLogin" "responseElements.ConsoleLogin"=Failure | stats count by identity.userName | sort -count`.

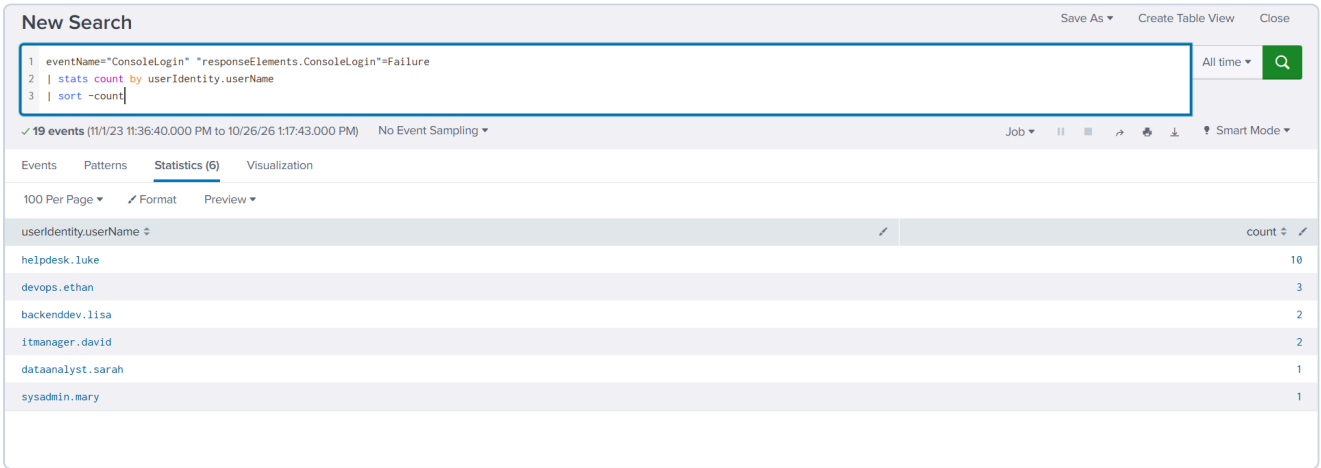
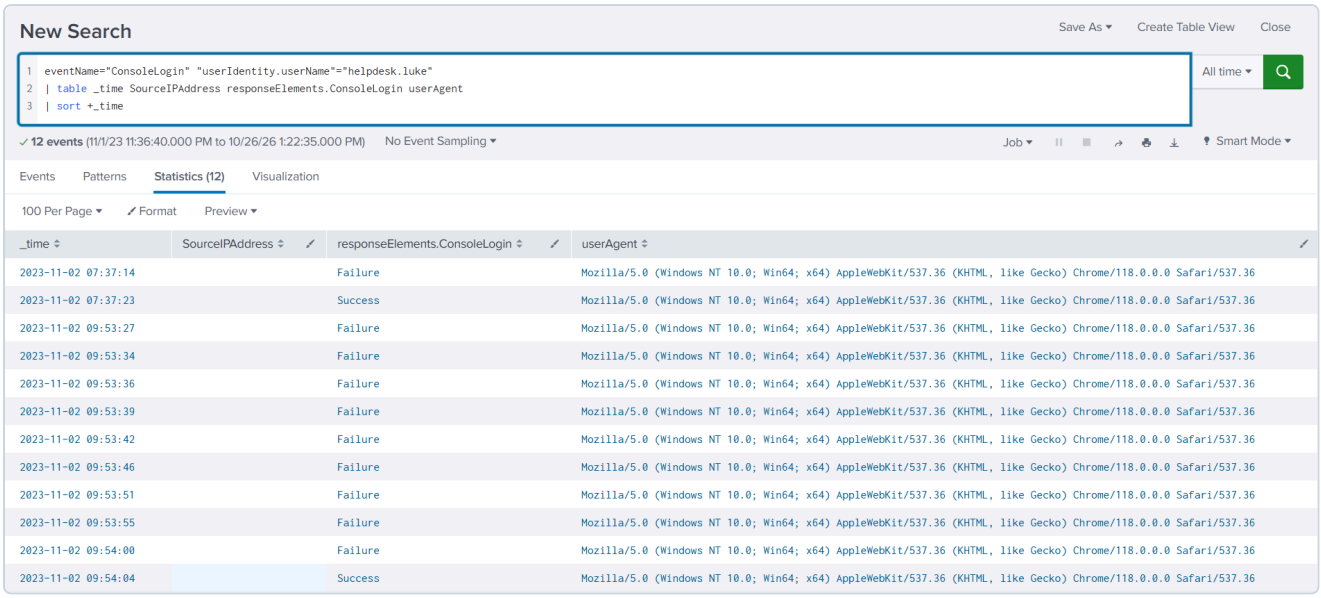


Figure 1. Splunk aggregation query revealing 10 failed login attempts for helpdesk.luke.

Drilling down into the specific login events for `helpdesk.luke` using `_time` and `SourceIPAddress` parameters confirmed the brute-force pattern leading up to successful access.

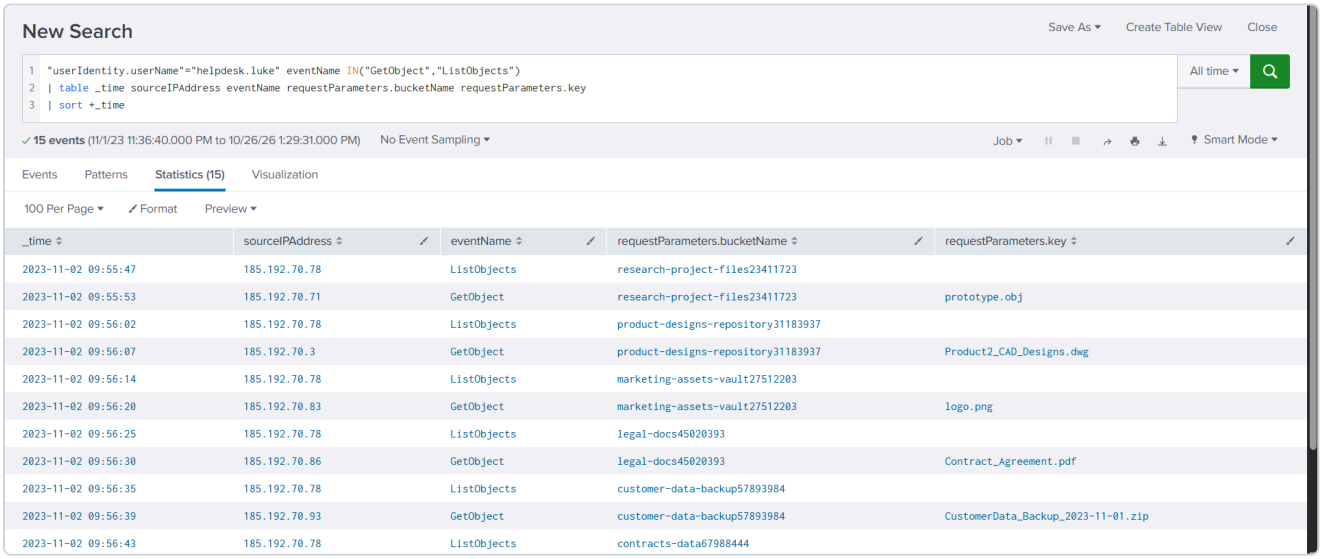


_time	SourceIPAddress	responseElements.ConsoleLogin	userAgent
2023-11-02 07:37:14		Failure	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36
2023-11-02 07:37:23		Success	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36
2023-11-02 09:53:27		Failure	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36
2023-11-02 09:53:34		Failure	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36
2023-11-02 09:53:36		Failure	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36
2023-11-02 09:53:39		Failure	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36
2023-11-02 09:53:42		Failure	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36
2023-11-02 09:53:46		Failure	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36
2023-11-02 09:53:51		Failure	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36
2023-11-02 09:53:55		Failure	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36
2023-11-02 09:54:00		Failure	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36
2023-11-02 09:54:04		Success	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36

Figure 2. Chronological event breakdown showing failure and success timestamps for helpdesk.luke.

Phase 2 - S3 Object Discovery & Data Exfiltration

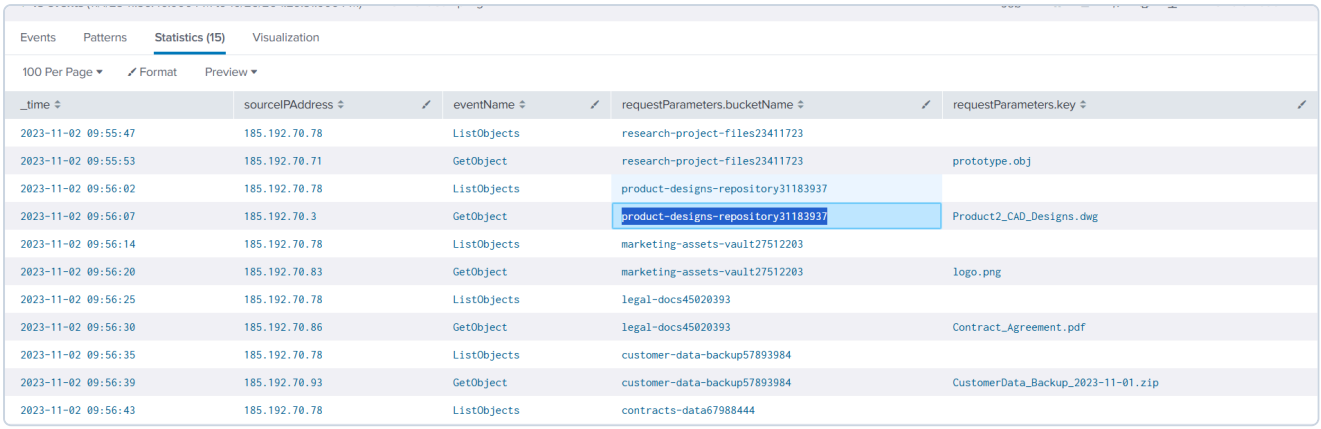
Following successful authentication, the attacker pivoted to storage enumeration. Filtering for `eventName IN("GetObject","ListObjects")` associated with `helpdesk.luke` highlighted systematic theft across multiple buckets.



_time	sourceIPAddress	eventName	requestParameters.bucketName	requestParameters.key
2023-11-02 09:55:47	185.192.70.78	ListObjects	research-project-files23411723	
2023-11-02 09:55:53	185.192.70.71	GetObject	research-project-files23411723	prototype.obj
2023-11-02 09:56:02	185.192.70.78	ListObjects	product-designs-repository31183937	
2023-11-02 09:56:07	185.192.70.3	GetObject	product-designs-repository31183937	Product2_CAD_Designs.dwg
2023-11-02 09:56:14	185.192.70.78	ListObjects	marketing-assets-vault27512203	
2023-11-02 09:56:20	185.192.70.83	GetObject	marketing-assets-vault27512203	logo.png
2023-11-02 09:56:25	185.192.70.78	ListObjects	legal-docs45020393	
2023-11-02 09:56:30	185.192.70.86	GetObject	legal-docs45020393	Contract_Agreement.pdf
2023-11-02 09:56:35	185.192.70.78	ListObjects	customer-data-backup57893984	
2023-11-02 09:56:39	185.192.70.93	GetObject	customer-data-backup57893984	CustomerData_Backup_2023-11-01.zip
2023-11-02 09:56:43	185.192.70.78	ListObjects	contracts-data67988444	

Figure 3. Splunk results detailing bucket enumeration and object downloads.

Inspecting individual entries confirmed unauthorized retrieval of proprietary engineering files, CAD drawings, legal contracts, and customer database backups.



Events Patterns Statistics (15) Visualization

100 Per Page ▾ Format Preview ▾

_time	sourceIPAddress	eventName	requestParameters.bucketName	requestParameters.key
2023-11-02 09:55:47	185.192.70.78	ListObjects	research-project-files23411723	
2023-11-02 09:55:53	185.192.70.71	GetObject	research-project-files23411723	prototype.obj
2023-11-02 09:56:02	185.192.70.78	ListObjects	product-designs-repository31183937	
2023-11-02 09:56:07	185.192.70.3	GetObject	product-designs-repository31183937	Product2_CAD_Designs.dwg
2023-11-02 09:56:14	185.192.70.78	ListObjects	marketing-assets-vault27512203	
2023-11-02 09:56:20	185.192.70.83	GetObject	marketing-assets-vault27512203	logo.png
2023-11-02 09:56:25	185.192.70.78	ListObjects	legal-docs45020393	
2023-11-02 09:56:30	185.192.70.86	GetObject	legal-docs45020393	Contract_Agreement.pdf
2023-11-02 09:56:35	185.192.70.78	ListObjects	customer-data-backup57893984	
2023-11-02 09:56:39	185.192.70.93	GetObject	customer-data-backup57893984	CustomerData_Backup_2023-11-01.zip
2023-11-02 09:56:43	185.192.70.78	ListObjects	contracts-data67988444	

Figure 4. Highlighted event showing exfiltration of Product2_CAD_Designs.dwg from product bucket.

Phase 3 - S3 Public Access Block Modifications

The adversary proceeded to weaken security posture by modifying bucket public access settings. Querying for `GetBucketPublicAccessBlock` and `PutBucketPublicAccessBlock` events uncovered configuration tampering.

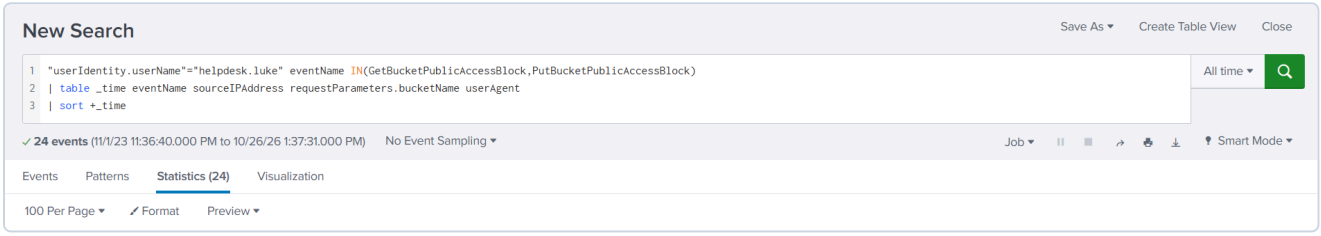
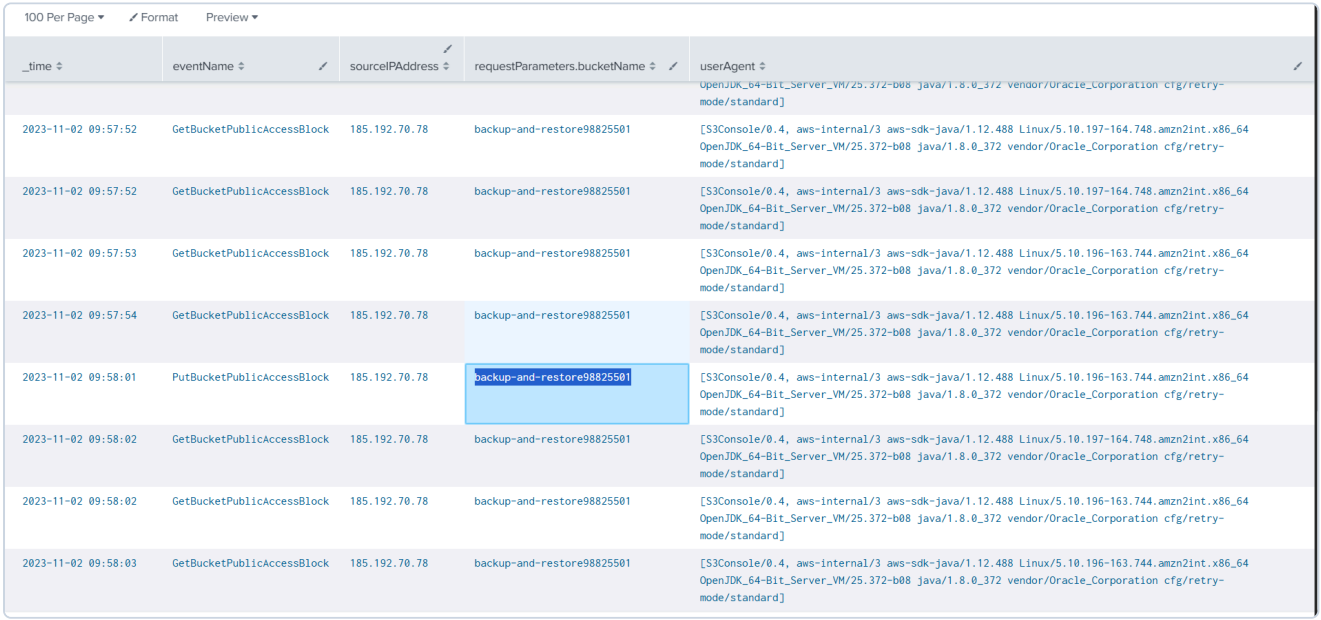


Figure 5. Splunk query filtering for public access block modification events.

CloudTrail logs explicitly verified that the attacker executed `PutBucketPublicAccessBlock` against `backup-and-restore98825501`.



100 Per Page ▾ Format Preview ▾

_time	eventName	sourceIPAddress	requestParameters.bucketName	userAgent
				OpenJDK_64-Bit_Server_VM/25.372-b08 java/1.8.0_372 vendor/Oracle_Corporation cfg/retry-mode/standard]
2023-11-02 09:57:52	GetBucketPublicAccessBlock	185.192.70.78	backup-and-restore98825501	[S3Console/0.4, aws-internal/3 aws-sdk-java/1.12.488 Linux/5.10.197-164.748.amzn2int.x86_64 OpenJDK_64-Bit_Server_VM/25.372-b08 java/1.8.0_372 vendor/Oracle_Corporation cfg/retry-mode/standard]
2023-11-02 09:57:52	GetBucketPublicAccessBlock	185.192.70.78	backup-and-restore98825501	[S3Console/0.4, aws-internal/3 aws-sdk-java/1.12.488 Linux/5.10.197-164.748.amzn2int.x86_64 OpenJDK_64-Bit_Server_VM/25.372-b08 java/1.8.0_372 vendor/Oracle_Corporation cfg/retry-mode/standard]
2023-11-02 09:57:53	GetBucketPublicAccessBlock	185.192.70.78	backup-and-restore98825501	[S3Console/0.4, aws-internal/3 aws-sdk-java/1.12.488 Linux/5.10.196-163.744.amzn2int.x86_64 OpenJDK_64-Bit_Server_VM/25.372-b08 java/1.8.0_372 vendor/Oracle_Corporation cfg/retry-mode/standard]
2023-11-02 09:57:54	GetBucketPublicAccessBlock	185.192.70.78	backup-and-restore98825501	[S3Console/0.4, aws-internal/3 aws-sdk-java/1.12.488 Linux/5.10.196-163.744.amzn2int.x86_64 OpenJDK_64-Bit_Server_VM/25.372-b08 java/1.8.0_372 vendor/Oracle_Corporation cfg/retry-mode/standard]
2023-11-02 09:58:01	PutBucketPublicAccessBlock	185.192.70.78	backup-and-restore98825501	[S3Console/0.4, aws-internal/3 aws-sdk-java/1.12.488 Linux/5.10.196-163.744.amzn2int.x86_64 OpenJDK_64-Bit_Server_VM/25.372-b08 java/1.8.0_372 vendor/Oracle_Corporation cfg/retry-mode/standard]
2023-11-02 09:58:02	GetBucketPublicAccessBlock	185.192.70.78	backup-and-restore98825501	[S3Console/0.4, aws-internal/3 aws-sdk-java/1.12.488 Linux/5.10.197-164.748.amzn2int.x86_64 OpenJDK_64-Bit_Server_VM/25.372-b08 java/1.8.0_372 vendor/Oracle_Corporation cfg/retry-mode/standard]
2023-11-02 09:58:02	GetBucketPublicAccessBlock	185.192.70.78	backup-and-restore98825501	[S3Console/0.4, aws-internal/3 aws-sdk-java/1.12.488 Linux/5.10.196-163.744.amzn2int.x86_64 OpenJDK_64-Bit_Server_VM/25.372-b08 java/1.8.0_372 vendor/Oracle_Corporation cfg/retry-mode/standard]
2023-11-02 09:58:03	GetBucketPublicAccessBlock	185.192.70.78	backup-and-restore98825501	[S3Console/0.4, aws-internal/3 aws-sdk-java/1.12.488 Linux/5.10.196-163.744.amzn2int.x86_64 OpenJDK_64-Bit_Server_VM/25.372-b08 java/1.8.0_372 vendor/Oracle_Corporation cfg/retry-mode/standard]

Figure 6. Audit log capturing PutBucketPublicAccessBlock execution by helpdesk.luke.

Phase 4 - Persistence & IAM Privilege Escalation

To establish permanent infrastructure access, the threat actor created a backdoor IAM user account and elevated its permissions to full administrator status.

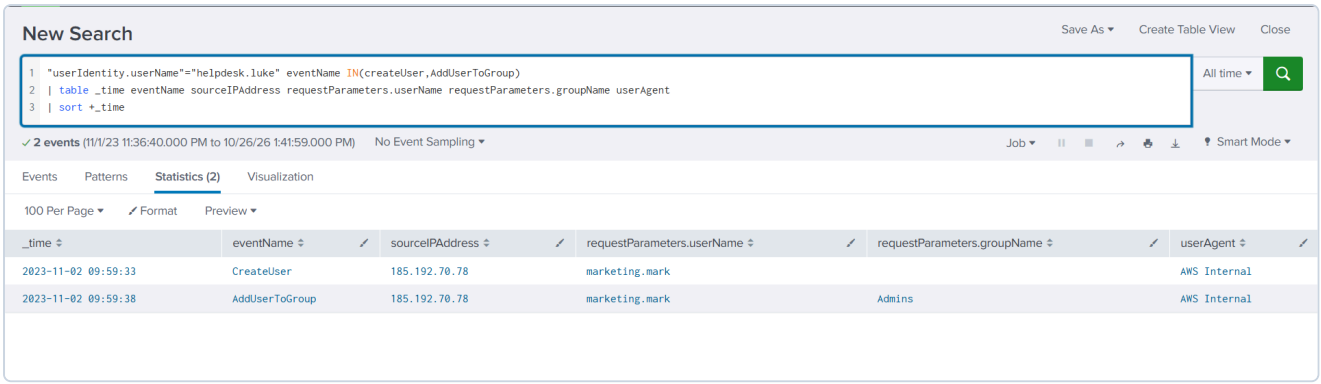


Figure 7. CloudTrail logs recording the creation of backdoor user marketing.mark.

The final administrative action added the newly created identity to the `Admins` IAM group.

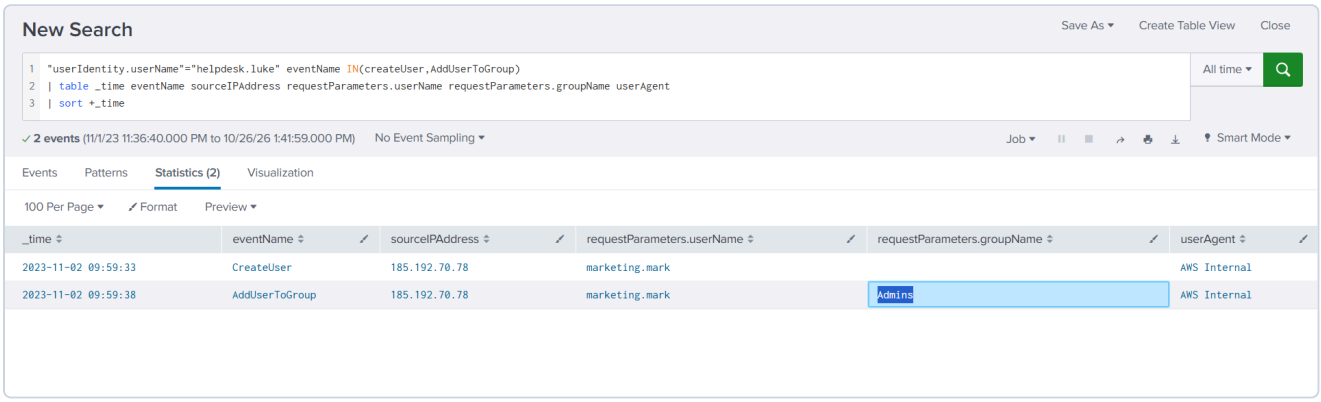


Figure 8. Audit event verifying backdoor account marketing.mark added to Admins group.

5. MITRE ATT&CK Mapping

Tactic	Technique ID	Observed Cloud Activity
Initial Access	T1078.004	Compromise of valid cloud accounts (`helpdesk.luke`) via brute-force.
Discovery	T1530	Automated enumeration and listing of S3 storage buckets.
Collection	T1213.003	Exfiltration of CAD designs, legal contracts, and customer database backups.
Defense Evasion	T1562.007	Modifying S3 bucket public access block controls (`PutBucketPublicAccessBlock`).
Persistence	T1136.003	Creation of unauthorized IAM backdoor user `marketing.mark` .
Privilege Escalation	T1098	Assigning backdoor identity to the administrative `Admins` group.

6. Indicators of Compromise (IoCs)

Indicator Type	Value / Identifier	Description
Attacker IP Range	`185.192.70.0/24` (`185.192.70.78`)	Primary external proxy and command source.
Compromised User	`helpdesk.luke`	Targeted support identity utilized for exfiltration.
Backdoor Account	`marketing.mark`	Unauthorized IAM user created and added to Admins group.
Exfiltrated Assets	`prototype.obj`, `Product2_CAD_Designs.dwg`, `CustomerData_Backup_2023-11-01.zip`	Proprietary engineering and customer database archives.

7. Impact Assessment

The security breach resulted in total compromise of sensitive corporate intellectual property, product designs, legal agreements, and customer backup archives. Furthermore, the creation of a persistent administrative backdoor grants the adversary unmonitored capability to re-enter the AWS environment at will.

8. Recommendations

- **Revoke Compromised Credentials:** Immediately disable and rotate access keys and passwords for `helpdesk.luke` and delete the unauthorized backdoor user `marketing.mark`.
- **Enforce Multi-Factor Authentication (MFA):** Require strict hardware-token MFA across all IAM user profiles, especially privileged and support accounts.
- **Implement Guardrails & SCPs:** Deploy AWS Service Control Policies (SCPs) preventing unauthorized modification of S3 Public Access Block settings.
- **Continuous SIEM Monitoring:** Configure automated real-time alerts for anomalous console logins from foreign IP ranges and mass S3 download spikes.

9. Conclusion

The forensic analysis highlights a sophisticated cloud attack combining credential brute-forcing, data exfiltration, and administrative persistence. Immediate remediation, identity hygiene, and hardened access controls are required to secure the AWS tenant.